

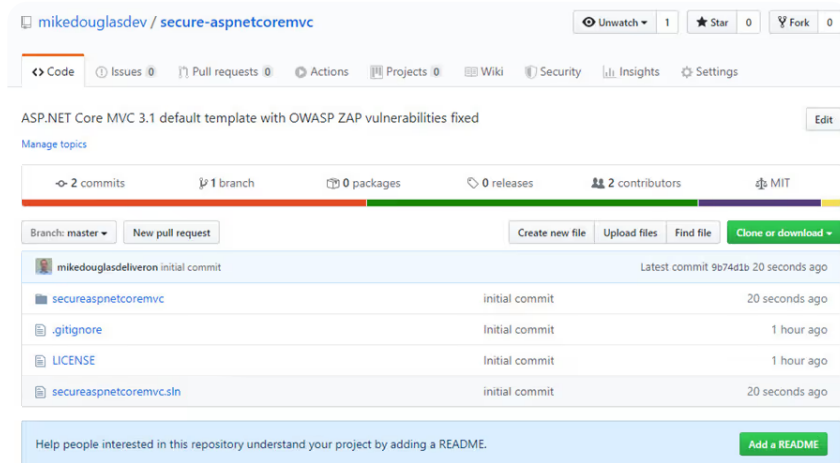
Using the OWASP ZAP Baseline Scan GitHub Action

March 1, 2023

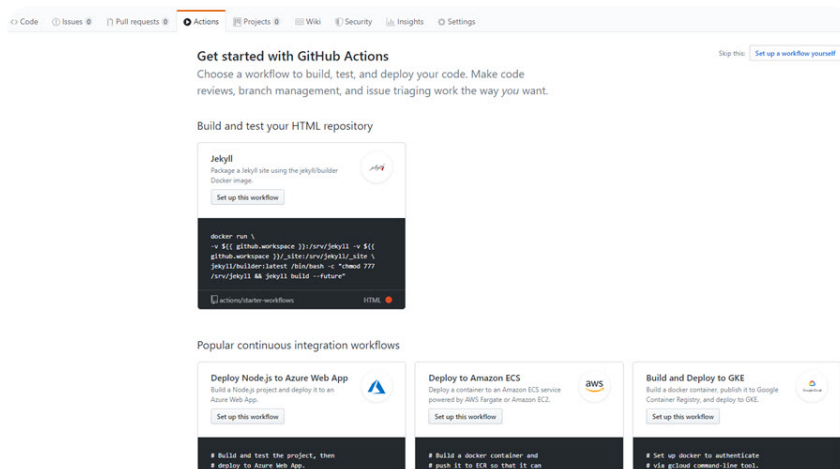
Incorporating security testing earlier in the process allows for security vulnerabilities to be fixed sooner and quicker to help eliminate costly vulnerabilities that can be exploited in production. Today, security testing can be performed throughout the software delivery pipeline. Once an application has been deployed, running a Dynamic Application Security Testing (DAST) scan can help detect if your web application has any exposed vulnerabilities. These tests can spider your website, detect if there are any vulnerabilities (passive mode) or actively send attacks to your website to simulate an attack.

OWASP ZAP is a popular open source client tool used for pen testing and can be included in our pipelines as an automated scan. The new OWASP ZAP Baseline Scan GitHub Action provides a very simple way to test your website from any Linux workflow runner. The action pulls down the latest stable (or optionally weekly) container, executes the baseline test, and then can be configured to create an issue to track the work to fix the vulnerabilities. The ZAP Scanning Report is also attached to run so you can look at additional details.

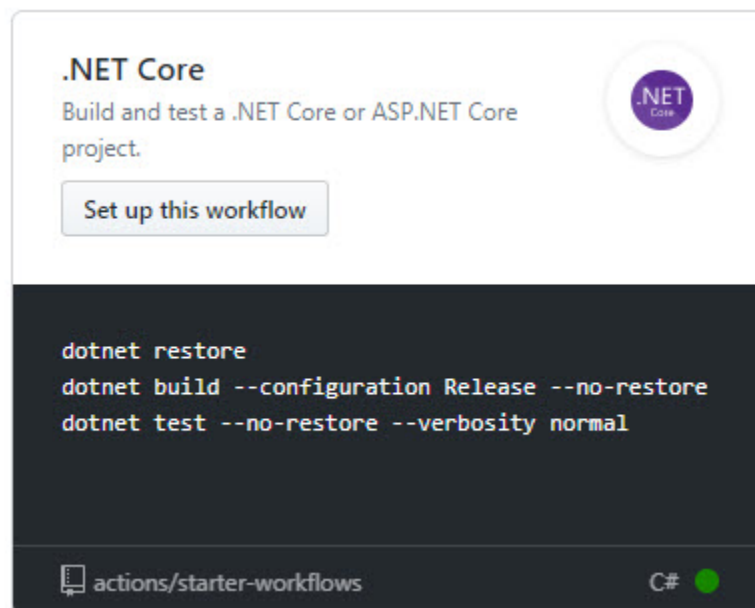
Using the following steps you can include the OWASP ZAP baseline scan in your GitHub repo's workflow. In this example, I am starting with a project using the ASP.NET Core MVC 3.1 default template in Visual Studio 2019 16.5.4. Your scan results might vary if you are using a different version or platform but all of the steps still apply.



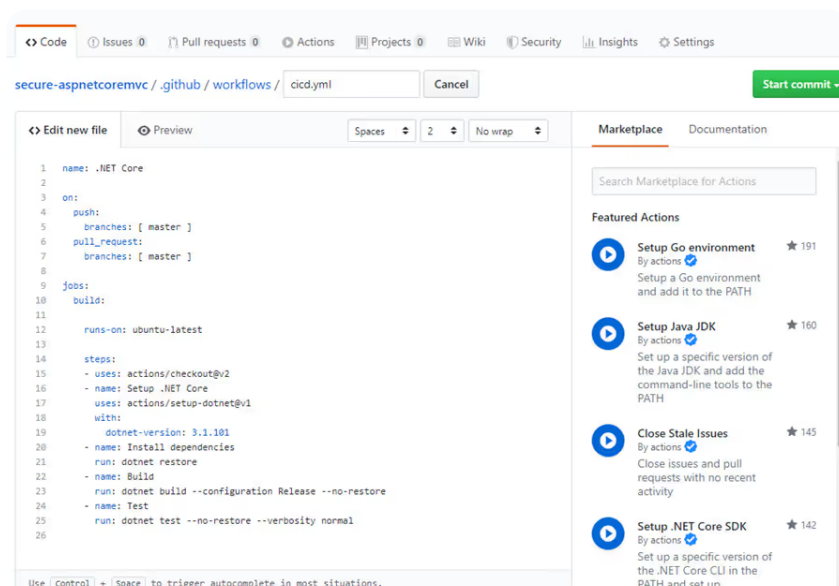
GitHub Actions provide a way to automate your development workflow including CI/CD. Here we will create a default workflow to build the .NET Core application. Click on the Actions tab to bring up the Workflow page.



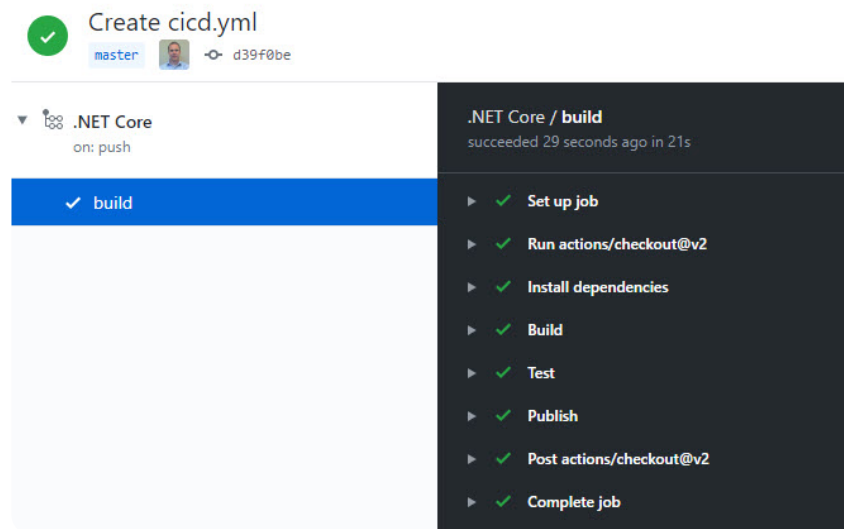
Expand the more workflows to find the .NET Core option. Click the Set up this workflow option to create a starter workflow script



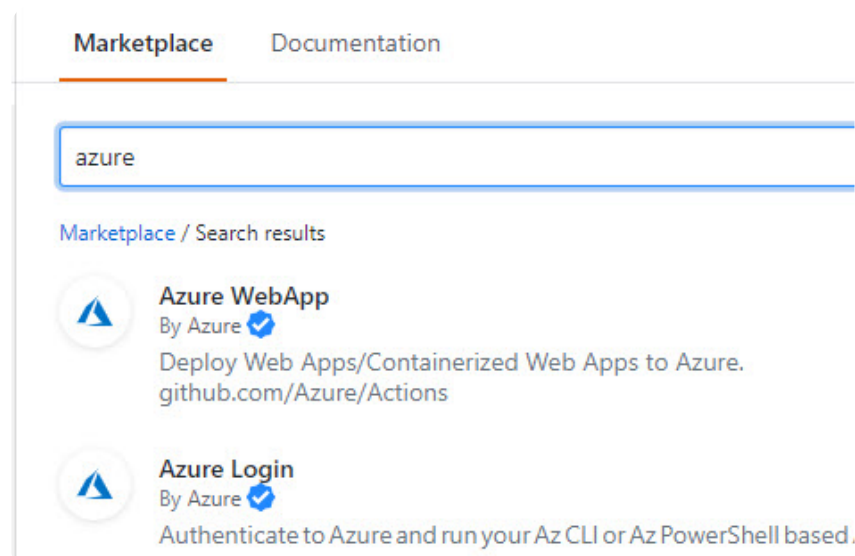
This will compile your application. I renamed it to CI/CD because we are going to deploy it Azure and run the OWASP ZAP scanner against it.



Commit the file and it should trigger the build process. This will ensure that the build succeeds before adding the deploying and scanning actions.



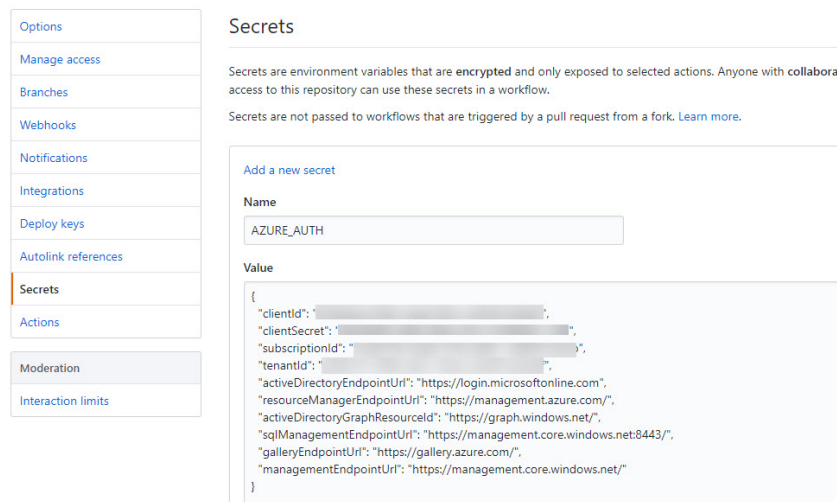
Add the Azure Actions to deploy the application to a preconfigured Azure App Service. Edit the workflow file again. This will display the Marketplace actions. Type Azure into the search and the Azure Web App and Azure Login actions should appear.



Add Azure Login by clicking on the title and then copying the snippet into the YML file. Most examples use publish profile but I prefer using service principal. Either option requires that the publish profile or the service principal information be stored as a secret for your repo. Right click on Settings and open it in a new browser tab. Use the Azure CLI to create the service principal. You can either do it locally or through the Cloud Shell. Replace the subscription ID with your subscription and run this command to generate the credentials.

```
az ad sp create-for-rbac --name "github_actions" --role contributor --scopes /subscriptions/11111111-0000-1111-0000-111111111111 --sdk-auth
```

Copy the full JSON output into the secret and give it a name like AZURE_AUTH.



The screenshot shows the GitHub 'Secrets' page. On the left is a sidebar with navigation links: Options, Manage access, Branches, Webhooks, Notifications, Integrations, Deploy keys, Autolink references, Secrets (highlighted), and Actions. Below these are 'Moderation' and 'Interaction limits'. The main content area is titled 'Secrets' and contains explanatory text about encrypted environment variables. A section titled 'Add a new secret' is visible, showing a form where the 'Name' is 'AZURE_AUTH' and the 'Value' is a JSON object containing Azure service principal credentials.

```
{
  "clientId": " ",
  "clientSecret": " ",
  "subscriptionId": " ",
  "tenantId": " ",
  "activeDirectoryEndpointUrl": "https://login.microsoftonline.com/",
  "resourceManagerEndpointUrl": "https://management.azure.com/",
  "activeDirectoryGraphResourceUrl": "https://graph.windows.net/",
  "sqlManagementEndpointUrl": "https://management.core.windows.net:8443/",
  "galleryEndpointUrl": "https://gallery.azure.com/",
  "managementEndpointUrl": "https://management.core.windows.net/"
}
```

Return to the workflow editor. Add the newly created secret as `${{ secrets.AZURE_AUTH }}`

```
# Login to Azure using Service Principal
- name: Azure Login
  uses: azure/login@v1
  with:
    creds: "${{ secrets.AZURE_AUTH }}"
```

Navigate back in the search results to copy the snippet for the Azure Web App. Most of this snippet will be removed because we are not using that. Add the app name and the package location. Both values were created as environment variables.

```

7 env:
8   AZURE_WEBAPP_NAME: secureaspnetcoremvc # set this to your application's name
9   AZURE_WEBAPP_PACKAGE_PATH: '/home/runner/work/secure-aspnetcoremvc/secure-aspnetcoremvc/secureaspnetcoremvc/bin/Debug/netcoreapp3.1/public
10   DOTNET_VERSION: '3.1.101' # set this to the dotnet version to use
11
12 # A workflow run is made up of one or more jobs that can run sequentially or in parallel
13 jobs:
14   # This workflow contains a single job called "build"
15   build:
16     # The type of runner that the job will run on
17     runs-on: ubuntu-latest
18
19     # Steps represent a sequence of tasks that will be executed as part of the job
20     steps:
21       # Checks-out your repository under $GITHUB_WORKSPACE, so your job can access it
22       - uses: actions/checkout@v2
23       with:
24         dotnet-version: ${{ env.DOTNET_VERSION }}
25
26       # Runs a single command using the runners shell
27       - name: Install dependencies
28         run: dotnet restore
29       - name: Build
30         run: dotnet build --configuration Release --no-restore
31       - name: Test
32         run: dotnet test --no-restore --verbosity normal
33       - name: Publish
34         run: dotnet publish
35
36       # Login to Azure using Service Principal
37       - name: Azure Login
38         uses: azure/login@v1
39         with:
40           creds: ${{ secrets.AZURE_AUTH }}
41
42       - name: Azure WebApp
43         uses: Azure/webapps-deploy@v2
44         with:
45           # Name of the Azure Web App
46           app-name: ${{ env.AZURE_WEBAPP_NAME }}
47           # Applies to Web App only: Path to package or folder. *.zip, *.war, *.jar or a folder to deploy
48           package: ${{ env.AZURE_WEBAPP_PACKAGE_PATH }}

```

At this point, your CI/CD workflow will build and deploy your web application to the Azure Web App. You can access your site via <https://yoursite.azurewebsites.net> to verify that it was deployed. The last step is to add the ZAP Scanner. Before adding this action to your workflow, first we need to create a GitHub Token with permission to create an issue with the security vulnerabilities to fix. Your scope might need to be changed if your repo is a private repo.

GitHub Apps

OAuth Apps

Personal access tokens

New personal access token

Personal access tokens function like ordinary OAuth access tokens. They can be used instead of HTTPS, or can be used to [authenticate to the API over Basic Authentication](#).

Note

zap_scanner

What's this token for?

Select scopes

Scopes define the access for personal tokens. [Read more about OAuth scopes.](#)

☐ repo	Full control of private repositories
☐ repo:status	Access commit status
☐ repo_deployment	Access deployment status
☒ public_repo	Access public repositories
☐ repo:invite	Access repository invitations
☐ workflow:read	Read workflow permissions

Adding the OWASP Zap Baseline Scan Action

Edit the workflow file again. This time search for the OWASP and select the OWASP ZAP Baseline Scan action. Copy the snippet to add to the workflow.

Marketplace / Search results / OWASP ZAP Baseline Scan



OWASP ZAP Baseline Scan

v0.2.0 ★ 29

Scans the web application with the OWASP ZAP Baseline Scan

[View full Marketplace listing](#)

Installation

Copy and paste the following snippet into your .yaml file.

Version: v0.2.0



```
- name: OWASP ZAP Baseline Scan
  uses: zaproxy/action-baseline@v0.2.0
  with:
    # GitHub Token to create issues in the repository
    token:
    # Target URL
    target:
    # Relative path of the ZAP configuration file
    rules_file_name: # optional
    # The Docker file to be executed
    docker_name: # default is owasp/zap2docker-stable
    # Additional command line options
    cmd_options: # optional
```

Add the token secret and the target website. You can comment out the other lines with a #.

```
- name: OWASP ZAP Baseline Scan
  uses: zaproxy/action-baseline@v0.2.0
  with:
    # GitHub Token to create issues in the repository
    token: ${ secrets.ISSUES_TOKEN }
    # Target URL
    target: https://${ env.AZURE_WEBAPP_NAME }.azurewebsites.net/
    # Relative path of the ZAP configuration file
    # rules_file_name: # optional
    # The Docker file to be executed
    # docker_name: # default is owasp/zap2docker-stable
    # Additional command line options
    # cmd_options: # optional
```

There are a few other updates I made to the script. You can see the latest version here. Save the workflow and that will trigger the workflow and you should see that it runs the scan and fails the build because it finds 8 warnings.

```
OWASP ZAP Baseline Scan
163 https://secureaspnetcoremvc.azurewebsites.net/Home/Privacy (200 OK)
164 https://secureaspnetcoremvc.azurewebsites.net/css/site.css (200 OK)
165 https://secureaspnetcoremvc.azurewebsites.net/lib/bootstrap/dist/css/bootstrap.min.css (200 OK)
166 https://secureaspnetcoremvc.azurewebsites.net/lib/jquery/dist/jquery.min.js (200 OK)
167 WARN-NEW: Server Leaks Version Information via "Server" HTTP Response Header Field [10036] x 9
168 https://secureaspnetcoremvc.azurewebsites.net/ (200 OK)
169 https://secureaspnetcoremvc.azurewebsites.net/robots.txt (404 Not Found)
170 https://secureaspnetcoremvc.azurewebsites.net/sitemap.xml (404 Not Found)
171 https://secureaspnetcoremvc.azurewebsites.net/Home/Privacy (200 OK)
172 https://secureaspnetcoremvc.azurewebsites.net/css/site.css (200 OK)
173 WARN-NEW: Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) [10037] x 9
174 https://secureaspnetcoremvc.azurewebsites.net/ (200 OK)
175 https://secureaspnetcoremvc.azurewebsites.net/robots.txt (404 Not Found)
176 https://secureaspnetcoremvc.azurewebsites.net/sitemap.xml (404 Not Found)
177 https://secureaspnetcoremvc.azurewebsites.net/Home/Privacy (200 OK)
178 https://secureaspnetcoremvc.azurewebsites.net/css/site.css (200 OK)
179 WARN-NEW: Content Security Policy (CSP) Header Not Set [10038] x 2
180 https://secureaspnetcoremvc.azurewebsites.net/ (200 OK)
181 https://secureaspnetcoremvc.azurewebsites.net/Home/Privacy (200 OK)
182 WARN-NEW: Cookie Without SameSite Attribute [10054] x 2
183 https://secureaspnetcoremvc.azurewebsites.net/ (200 OK)
184 https://secureaspnetcoremvc.azurewebsites.net/robots.txt (404 Not Found)
185 FAIL-NEW: 0 FAIL-INPROG: 0 WARN-NEW: 8 WARN-INPROG: 0 INFO: 0 IGNORE: 0 PASS: 42
186 ##[error]The ZAP Baseline scan has failed, starting to analyze the alerts. err: Error: The process '/usr/bin/docker' failed with exit code 2
187 Alerts present in the current report: true
188 Process completed successfully and a new issue #1 has been created for the ZAP Scan.
189 Total size of all the files uploaded is 105823 bytes
190 Finished uploading artifact zap_scan. Reported size is 105823 bytes. There were 0 items that failed to upload
```

The workflow failed because it found one or more alerts. An Issue was created to create actionable and traceable work for fixing the alerts.

ZAP Scan Baseline Report #1

[Open](#)

mikedouglasdev opened this issue 8 hours ago · 0 comments

mikedouglasdev commented 8 hours ago

Owner

...

- Site: <https://secureaspnetcoremvc.azurewebsites.net>
 - New Alerts
 - Incomplete or No Cache-control and Pragma HTTP Header Set [10015] total: 4:
 - <https://secureaspnetcoremvc.azurewebsites.net/Home/Privacy>
 - <https://secureaspnetcoremvc.azurewebsites.net/css/site.css>
 - <https://secureaspnetcoremvc.azurewebsites.net/>
 - <https://secureaspnetcoremvc.azurewebsites.net/lib/bootstrap/dist/css/bootstrap.min.css>
 - Content Security Policy (CSP) Header Not Set [10038] total: 2:
 - <https://secureaspnetcoremvc.azurewebsites.net/>
 - <https://secureaspnetcoremvc.azurewebsites.net/Home/Privacy>
 - X-Content-Type-Options Header Missing [10021] total: 7:
 - <https://secureaspnetcoremvc.azurewebsites.net/>
 - <https://secureaspnetcoremvc.azurewebsites.net/js/site.js?v=8xfAw9RUJ1E4NycpKEjCND6o5v4RPHxdBq5wDnkeY>
 - <https://secureaspnetcoremvc.azurewebsites.net/css/site.css>
 - <https://secureaspnetcoremvc.azurewebsites.net/lib/bootstrap/dist/js/bootstrap.bundle.min.js>
 - <https://secureaspnetcoremvc.azurewebsites.net/lib/jquery/dist/jquery.min.js>
 - ...

Assignees

No one—assign yourself

Labels

None yet

Projects

None yet

Milestone

No milestone

Linked pull requests

Successfully merging a pull request may close this issue.

None yet

Notifications

Customize

Unsubscribe

The full OWASP ZAP Scan report is also attached as an artifact to the workflow run. The report contains additional information about the alerts.

ZAP Scanning Report

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	1
Low	7
Informational	1

Alert Detail

Medium (Medium)	X-Frame-Options Header Not Set
Description	X-Frame-Options header is not included in the HTTP response to protect against 'ClickJacking' attacks.
URL	https://secureaspnetcoremvc.azurewebsites.net/Home/Privacy
Method	GET
Parameter	X-Frame-Options
URL	https://secureaspnetcoremvc.azurewebsites.net/
Method	GET
Parameter	X-Frame-Options
Instances	2
Solution	Most modern Web browsers support the X-Frame-Options HTTP header. Ensure it's set on all web pages returned by your site (if you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. ALLOW-FROM allows specific websites to frame the web page in supported web browsers).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
CWE Id	16
WASC Id	15
Source ID	3

At this point, you built, deployed, and performed a baseline DAST scan against the deployed application. The alerts must be fixed or ignored to get the workflow passing. In the next post, I will show how to fix the alerts.

Related Topics:

[DevOps](#)[Security](#)[Previous post](#)[Using a Single Date Picker with Conditional Filtering in Power BI](#)[Next post](#)[Utilizing Bicep Parameter Files with ALZ-Bicep](#)